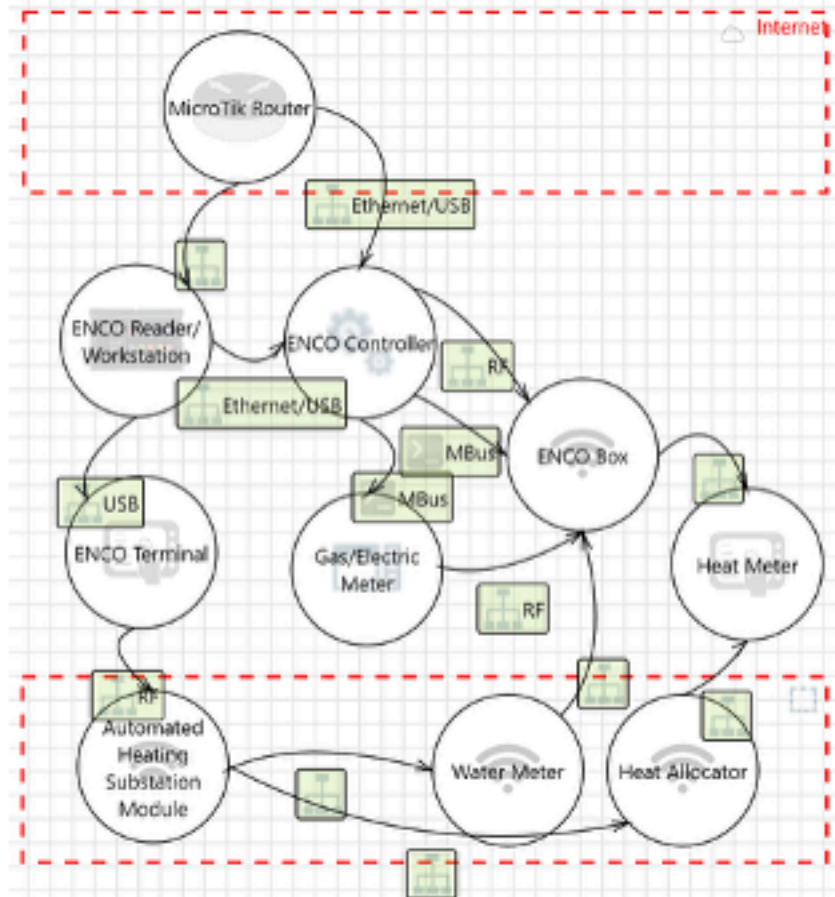


ASTRAL Example Pipeline



Data Flow Diagram (DFD)

Architectural Narrative

Attacker or Attack-Capable Entities The diagram implies potential adversaries at multiple levels:

- External Attackers:** Entities with network access to the system via exposed interfaces (e.g., Internet-facing APIs, remote management ports, or cloud connections).
- Internal Threat Actors:** Authorized users (e.g., operators, maintenance personnel, or administrators) with direct or privileged access to HMI, engineering workstations, or field devices. Misconfigurations or credential misuse are implicit risks.
- Supply Chain Compromises:** Third-party vendors or integrators with access to firmware/software updates for PLCs, controllers, or IoT gateways.
- Physical Intruders:** Entities with direct access to field-level devices (e.g., tampering with sensors, actuators, or local control panels).
- Compromised Components:** Devices or systems within the architecture that, if breached (e.g., a router or HMI), could pivot to other zones (e.g., lateral movement from IT to OT).

Key Components

- Field Level (Purdue Level 0-3):**
 - Sensors:** Temperature, flow, or pressure sensors transmitting analog/digital signals to controllers.
 - Actuators:** Valves, pumps, or heating elements receiving control commands from PLCs/RTUs.
 - Local Controllers:** PLCs (Programmable Logic Controllers) or RTUs (Remote Terminal Units) executing ladder logic or control algorithms.
 - IoT Gateways:** Edge devices aggregating sensor data and translating protocols (e.g., Modbus to MQTT).
- Control Level (Purdue Level 2):**
 - SCADA/HMI Workstations:** Human-machine interfaces for operator monitoring and manual overrides.
 - Historians:** Databases storing time-series data (e.g., temperature logs, actuator status).
 - Engineering Workstations:** Used for PLC programming, firmware updates, or configuration changes.
- Site/Operational Level (Purdue Level 3):**
 - Site Supervisory Systems:** Centralized control servers coordinating multiple PLCs or subsystems.
 - Firewalls/IPS:** Network security appliances segmenting IT/OT traffic.
- Enterprise Level (Purdue Level 4-5):**
 - Enterprise IT Systems:** ERP, CRM (Customer Relationship Management Systems), or cloud platforms for analytics/remote monitoring.
 - Remote Access Gateways:** VPN concentrators or jump servers for off-site maintenance.
- Network Infrastructure:**
 - Industrial Switches/Routers:** Connecting field devices to control networks (e.g., Ethernet/IP, PROFINET).

Architectural Reconstruction

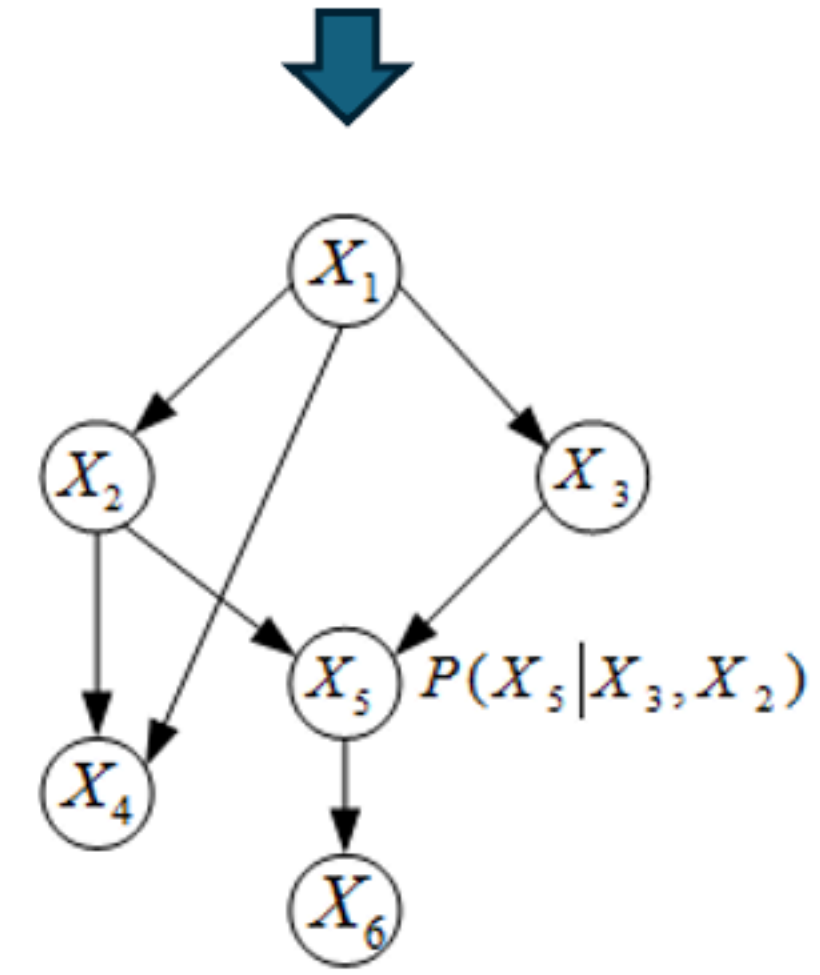
Threat Model

Threat Type	Scenario	Potential Impact
Tampering	An attacker with physical access to the field devices (e.g., sensors or actuators) could tamper with their hardware or firmware to manipulate temperature readings or control signals. For example, by exploiting unprotected JTAG ports or unencrypted firmware updates, the attacker could alter the reported temperature values or override control commands, causing the heating system to operate outside safe parameters. This could lead to overheating, equipment damage, or even fire hazards. (CVE-2021-33956, a vulnerability in firmware update mechanisms, has been observed in attacks like "FrostyGeep").	Overheating of the system, equipment damage, or fire hazards due to incorrect temperature readings or control signals.
Denial of Service	An attacker could launch a DoS attack on the central controller by flooding it with malicious network traffic, exploiting vulnerabilities in the communication protocol (e.g., Modbus/TCP). For instance, sending a high volume of requests to the controller could overwhelm its processing capability, leading to system unresponsiveness. This could disrupt the heating system's operation, causing discomfort or, in critical environments like hospitals, endangering patients. (CVE-2018-10615, a vulnerability in Modbus/TCP implementations, has been exploited in attacks like "BlackEnergy").	Disruption of heating system operation, leading to discomfort or endangering patients in critical environments.
Elevation of Privilege	An attacker with access to the maintenance interface could exploit weak authentication mechanisms to elevate their privileges. For example, default or easily guessable credentials could allow the attacker to gain administrative access to the central controller. With elevated privileges, the attacker could modify system configurations, disable safety controls, or issue unauthorized commands, potentially causing physical damage or safety incidents. (CVE-2017-7921, a vulnerability in authentication mechanisms, has been observed in attacks like "Trinix").	Unauthorized modifications to system configurations, disabling of safety controls, or issuance of unauthorized commands, leading to physical damage or safety incidents.

Threat Modelling (STRIDE-LM)

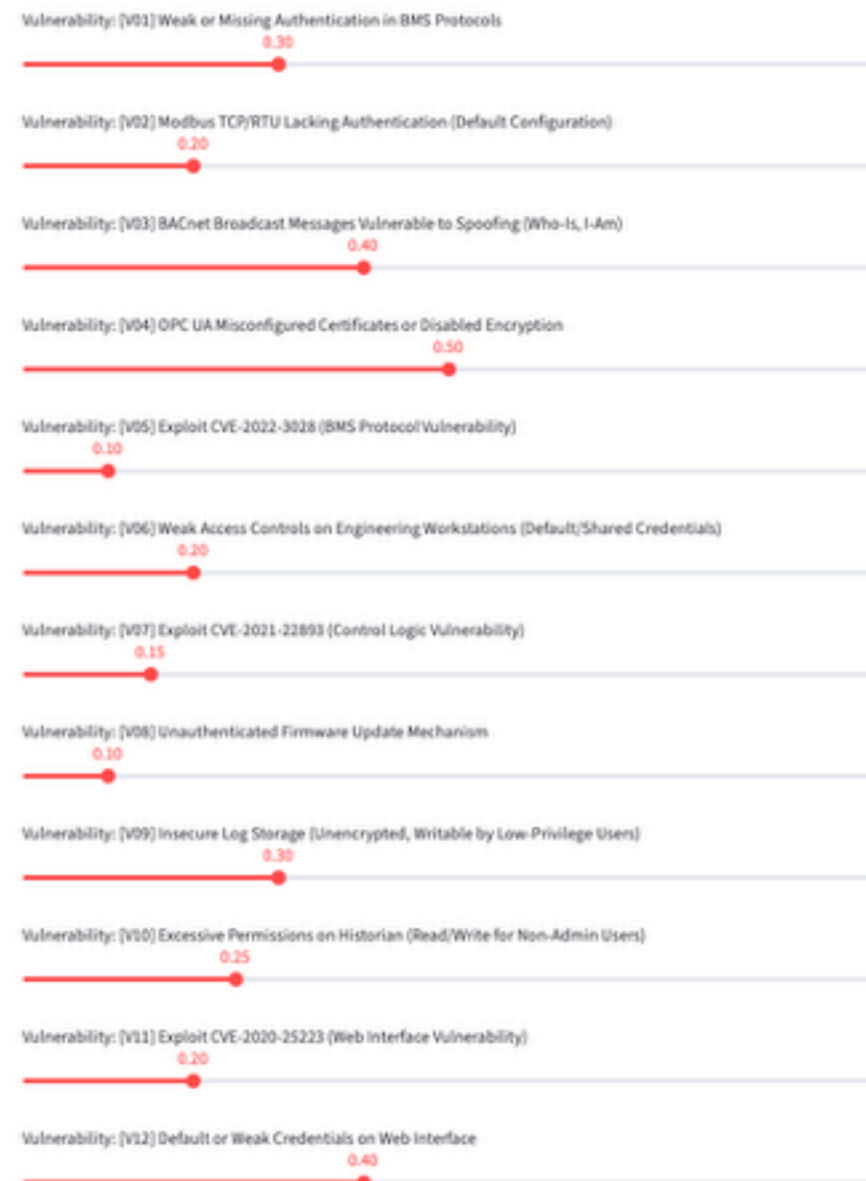


Attack Modelling (Attack Tree)

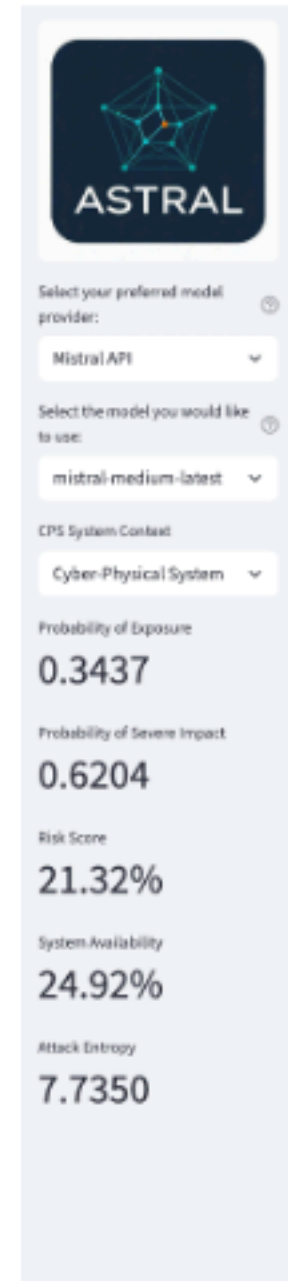


Bayesian Network Model Representation

Countermeasure Portfolio



Countermeasure Portfolio Simulation



Probabilistic Risk Analysis

Error system installation date: 01/01/2024

Attacker ID in the system model: [U01] Attacker

Load/Reset Model Attributes

Attack Feasibility (AF) Modifier: 0.50

Attributes extracted successfully. You can now adjust the attack feasibility (AF) modifier to incorporate attack characteristics in the analysis.

Asset Attributes

IP ID	IP Name
[A01] Building Management System (BMS) with Weak Authentication	Building Management System (BMS)
[A02] Wireless Field Devices (Sensors/Actuators)	Wireless Field Devices (Sensors/Actuators)
[A03] Programmable Logic Controllers (PLCs) with Modifiable Logic	Programmable Logic Controllers (PLC)
[A04] Human-Machine Interfaces (HMIs) with Manual Override Capabilities	Human-Machine Interfaces (HMI) and
[A05] Historian Databases Storing Process Logs/Audit Trails	Historian Databases Storing Process
[A07] PLC Event Logs or Time Synchronization Records	PLC Event Logs or Time Synchronization
[A08] HMI Web Interface with Sensitive Configuration Data	HMI Web Interface with Sensitive Con
[A09] Engineering Workstations with Project Files/Backups	Engineering Workstations with Projec
[A10] Industrial Switches/Routers Connecting OT Networks	Industrial Switches/Routers Connecti
[A11] PLCs with Limited Processing/Memory Resources	PLCs with Limited Processing/Memor

Vulnerability Attributes

IP ID	IP Name
[V01] Exploit CVE-2022-3028 (Authentication Bypass in BMS Protocol)	Exploit CVE-2022-3028 (Aut
[V02] Weak Encryption or Default Credentials in Wireless Protocols (Zigbee/LokaMAN)	Weak Encryption or Default
[V03] Exploit CVE-2021-22893 (Unauthorized PLC Control Logic Modification)	Exploit CVE-2021-22893 (in
[V04] Tamper with PLC Firmware via Supply Chain or Physical Access	Tamper with PLC Firmware
[V05] Exploit Weak HMI Authentication or Session Hijacking	Exploit Weak HMI Authentic
[V06] Exploit CVE-2020-14859 (Unauthorized Access to Log Files)	Exploit CVE-2020-14859 (in
[V07] Spoof NTP/PTP Time Synchronization for PLCs	Spoof NTP/PTP Time Synch

AutomationML (XML) Representation

Generated AutomationML File

```
<?xml version="1.0" encoding="utf-8"?>
<CAEXFile SchemaVersion="3.0" FileName="cps.xml" xmlns:ca="http://www.w3.org/2001

<InstanceHierarchy Name="CPS_Assets">
  <Version>1.0</Version>

  <!-- Users/Attackers -->
  <InternalElement Name="Attacker" ID="[U01] Attacker" RefBaseSystemUnitPath="As
  <Attribute Name="HumanErrorEstimationPercentage" AttributeDataType="xs:string"
  <Value>100</Value>
  </Attribute>
  <ExternalInterface Name="AttackerInterface" ID="[U01]Attacker_ExtIF" RefBase
  </InternalElement>

  <!-- Assets -->
  <InternalElement Name="Building Management System (BMS) Protocols (Modbus, BAC
  <Attribute Name="AutomationEquipments" AttributeDataType="xs:string" RefAttr
  <Attribute Name="Vendor" AttributeDataType="xs:string">
    <Value>Generic</Value>
  </Attribute>
  <Attribute Name="Part" AttributeDataType="xs:string">
    <Value>BMS-001</Value>
  </Attribute>
  <Attribute Name="Product" AttributeDataType="xs:string">
    <Value>BMS Protocol Stack</Value>
  </Attribute>
  <Attribute Name="Version" AttributeDataType="xs:string">
    <Value>1.0</Value>
  </Attribute>
  <Attribute Name="FailureRatePerHour" AttributeDataType="xs:float">
    <Value>9.0001</Value>
  </Attribute>
  <Attribute Name="Impact Rating" AttributeDataType="xs:float">
    <Value>9.2</Value>
  </Attribute>
  <Attribute Name="Date of first use" AttributeDataType="xs:string">
    <Value>2020-01-01</Value>
  </Attribute>
  </InternalElement>

  <ExternalInterface Name="BMS_Protocols_Interface" ID="[A01]BMS_Protocols_Ext
  <ExternalInterface Name="ModbusTCP" RefBaseClassPath="AutomationMLInterface
  <ExternalInterface Name="BACnet" RefBaseClassPath="AutomationMLInterfaceC
  <ExternalInterface Name="OPCUA" RefBaseClassPath="AutomationMLInterfaceCa
  </ExternalInterface>
  </InternalElement>
```